

# KeenPay

Agentic commerce with bounded AI

---

KeenPay — Authentication & Authorization

Authentication

01 September 2026

<https://github.com/ambitiouss22/KeenPay>

# KeenPay — Authentication & Authorization

Production fintech auth for KeenPay. Implements [docs/API\\_SPEC.md](#) section 1.

## Auth methods

| Method     | Header                                                  | Use case                                       |
|------------|---------------------------------------------------------|------------------------------------------------|
| JWT Bearer | <code>Authorization: Bearer &lt;access_token&gt;</code> | Human users (shopper, support, manager, admin) |
| API Key    | <code>X-API-Key: kp_...</code>                          | Service accounts, workers, integrations        |
| WebSocket  | <code>?token=&lt;JWT&gt;</code>                         | Live session + trace streaming                 |

## Token lifecycle

|                            |                                                      |
|----------------------------|------------------------------------------------------|
| POST /api/v1/auth/login    | → access_token (60m) + refresh_token (7d)            |
| POST /api/v1/auth/refresh  | → rotated pair (refresh token reuse → revoke family) |
| POST /api/v1/auth/revoke   | → invalidate refresh token                           |
| GET /api/v1/auth/me        | → current user profile                               |
| POST /api/v1/auth/api-keys | → admin only; key shown once                         |

## Roles & permissions

| Role          | Permissions                                   |
|---------------|-----------------------------------------------|
| shopper       | Own sessions, catalog read, own orders        |
| support_agent | Read sessions/orders/audit, view escalations  |
| manager       | Resolve escalations, HITL overrides (audited) |
| admin         | Full access including API key management      |
| service       | Webhook processing, internal reads            |

RBAC matrix: [api/core/rbac.py](#)

## Security controls

- Account lockout — 5 failed logins → 15 min lock (`users.locked_until`)
- Refresh token rotation — family\_id detects reuse attacks
- Append-only auth audit — `auth_audit_log` table, DB trigger blocks mutation
- Rate limits — login: 10/min, auth routes: 30/min, global: 120/min
- Security headers — HSTS (HTTPS), nosniff, DENY frame, no-store cache
- Request ID — `X-Request-ID` on every response for trace correlation

## Database

Auth tables (`users`, `refresh_tokens`, `api_keys`, `auth_audit_log`) are included in `docs/SCHEMA.sql`.

```
psql $DATABASE_URL -f docs/SCHEMA.sql
```

Shell

Dev users (password: `KeenPayDev1!`):

| Email               | Role          |
|---------------------|---------------|
| shopper@keenpay.dev | shopper       |
| support@keenpay.dev | support_agent |
| manager@keenpay.dev | manager       |
| admin@keenpay.dev   | admin         |

## Local dev shortcut

```
curl http://localhost:8000/api/v1/dev/token?user_id=user_dev_shopper
```

Shell

Disabled when `APP_ENV=production`.

## Payment boundary (unchanged)

Auth does not grant payment permission. Razorpay calls still require:

- 1 `guardrail_decision == APPROVED`
- 2 `user_confirmed_payment == True`
- 3 `assert_payment_gates()` pass

See `docs/GUARDRAILS_AND_SAFETY.md`.